



월간 국방과 기술

보안은 불신으로부터, 제로트러스트 모델의 군 적용 필요성 제고



작성자 : 전보국 외 2명(210.223.xxx.xxx)

입력 2021-09-23 13:45:53

조회수 2291 | 댓글 0 | 추천 0

보안은 불신으로부터, 제로트러스트 모델의 군 적용 필요성 제고

전보국 Northeastern Univ 정보보호 석사

최경택 고려대학교 석사과정

박규순 KAIST 석사과정



국가 범위의 사이버 공격

지난 6월 18일, 국회 정보위 국회의원이 한국원자력연구원(Korea Atomic Energy Research Institute, 이하 KAERI)이 북한으로 추정되는 세력에 의해 해킹된 사건을 공개했고, 연이어 국가 핵심기술을 다루는 주요 방산업체인 대우조선해양과 한국항공우주산업(이하 KAI)에 대한 해킹 사건까지 언론이 보도하면서 사이버 보안의 중요성이 다시금 강조되고 있다.

앞서 언급한 사례들은 개인이나 단체, 민간기업을 대상으로 하는 단순한 사이버 공격이 아니라 다수의 민감한 자료를 관리 또는 취급하여 국가안보에 치명적인 영향을 미칠 수 있는 국가기관과 방산업체를 대상으로 하는 ‘국가 범위의 사이버 공격’이라는 점에서 국가 지도부는 물론 일반 국민에게도 큰 불안으로 다가오고 있다. 이와 같은 국가 범위의 보안 이슈는 현재의 우리나라에만 국한된 문제가 아니라 과거부터 세계 각국에서 지속적으로 발생해 왔으며 미래에는 더욱 치밀하고 다양한 위협으로 다가올 것이다.

최근에 발생한 주요 보안 이슈의 사례로는 ❶ 공급망 공격을 이용한 ‘솔라윈즈’ 사태, ❷ 미 동부 송유관 ‘콜로니얼 파이프라인’ 공격, ❸ MicroSoft사의 Exchange 사태 등이 있었다. 이 세 사건은 모두 미국을 대상으로 하는 공격이었으며 사안의 심각성을 느낀 미국 행정부는 지난 5월 사이버 보안에 대한 긴급 행정명령을 하달했다.



BRIEFING ROOM

Executive Order on Improving the Nation's Cybersecurity

MAY 12, 2021 • PRESIDENTIAL ACTIONS

[그림 1] 미국 백악관에서 하달한 국가 사이버 보안 개선을 위한 행정 명령

내부적인 능력 개선에 관한 내용을 제외한 상기 행정명령의 주요 내용은 다음과 같다.

- (1) 사이버 보안 사고에 대한 정부와 민간영역의 첩보 및 정보 공유 장벽 제거
- (2) 정부의 사이버 보안 현대화(제로 트러스트 아키텍처와 클라우드 서비스 적용)
- (3) 소프트웨어 공급망 보안 강화
- (4) 사이버 보안 취약점 및 사고에 대한 대응 전술 표준화

미국 행정부의 사이버 보안에 관한 긴급 행정명령이 비록 보안전문가들의 관점에서 평가했을 때 기술적으로 부족한 점이 있음은 부인할 수 없지만, 한편으로는 미국이 국가적 차원에서 사이버 보안의 중요성을 제대로 인식하고 있음을 보여 주는 좋은 사례로 여겨진다. 또한 미국이 IT 환경의 변화에 발맞추어 사이버 보안의 트렌드를 따라가고자 노력하고 있다는 점이 긍정적으로 평가된다.

미국의 사이버 보안 행정명령 주요 항목 중, 이 글에서는 제2항 정부의 사이버 보안 현대화 부분을 집중적으로 다루고자 한다. 제2항을 좀 더 구체적으로 들여다보면 제로 트러스트 모델에 관한 내용이 주요 골자를 이루고 있음을 확인할 수 있다. 제로 트러스트 모델을 간단히 말하자면 ‘네트워크에 접근하는 것은 어떤 것도 믿을 수 없다’라는 불신을 기반으로 하는 보안 모델이다. 미 행정부는 왜 이 모델을 정부에 적용하려고 하는 것일까?

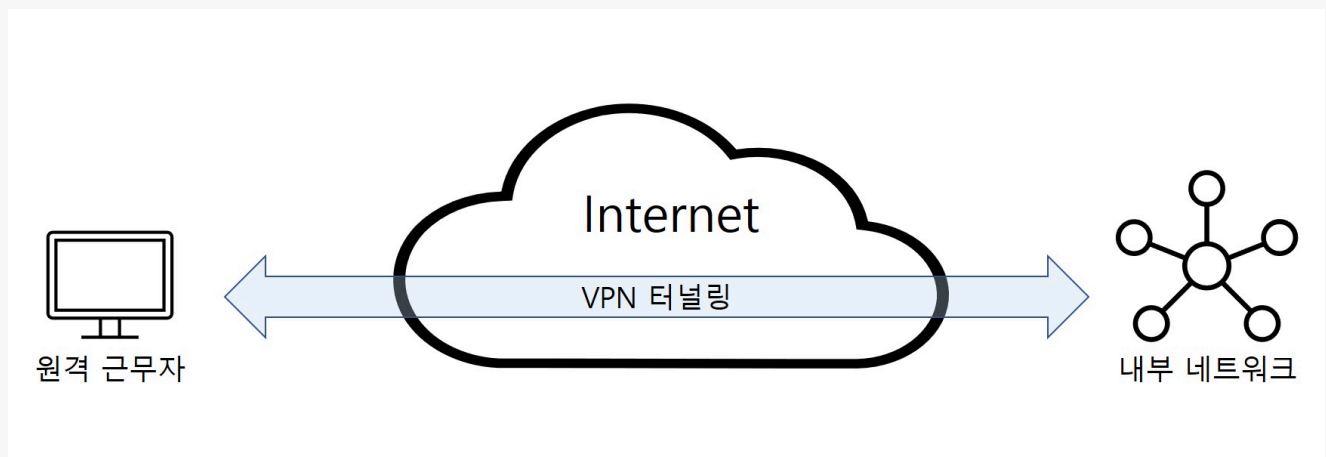
포스트 코로나 시대의 사이버 보안

지난 2019년 12월 최초 발생한 것으로 추정되는 COVID-19는 전 세계적으로 대유행하며 현재까지 우리 삶의 모습을 크게 바꾸어 놓고 있다. 마스크는 일상생활의 필수품이 되었고, 모든 국가는 대유행을 극복하고 COVID-19 이전의 모습으로 되돌아가는 것을 목표로 국가 정책을 추진하고 있으며, 비대면 서비스와 비대면

톱 가상화)를 이용한 재택근무와 Zoom, MS TEAM, Slack 등의 솔루션을 활용한 원격회의는 이제 낯설지 않은 풍경이다.

VPN 서비스는 가상 사설 네트워크를 의미하며 공용 네트워크(예 : 인터넷) 내부에서 가상의 네트워크를 구성하는 것을 의미한다. [그림 2]처럼 일종의 터널을 뚫어서 출발지와 종착지에 있는 컴퓨터만 VPN 터널을 사용할 수 있도록 했다고 생각하면 이해가 쉽다. 출발지와 종착지에 있는 두 컴퓨터를 제외하고는 이 터널 내부를 들여다볼 수 없기 때문에 이 터널을 이용한 통신은 안전하다고 볼 수 있다.

이 VPN을 이용하면 원격으로도 안전하게 내부 네트워크에 접속할 수 있다. 물론, VPN을 이용할 때에는 승인된 이용자만이 내부 네트워크에 접속할 수 있도록 로그인이나 OTP 인증과 같은 인증을 거쳐야 한다. 그러나 모든 기술과 프로그램이 완전무결할 수 없듯이 이 VPN도 취약점을 가질 수 있다. 좀 더 정확히 말하자면 VPN 서비스 자체의 취약점이라기보다는 VPN을 이용할 수 있도록 도와주는 프로그램이 보유한 취약점인데, 대표적으로는 로그인과 같은 인증절차를 우회하는 취약점을 노린 해킹 공격이 가능하다.



[그림 2] VPN 터널링 개념도

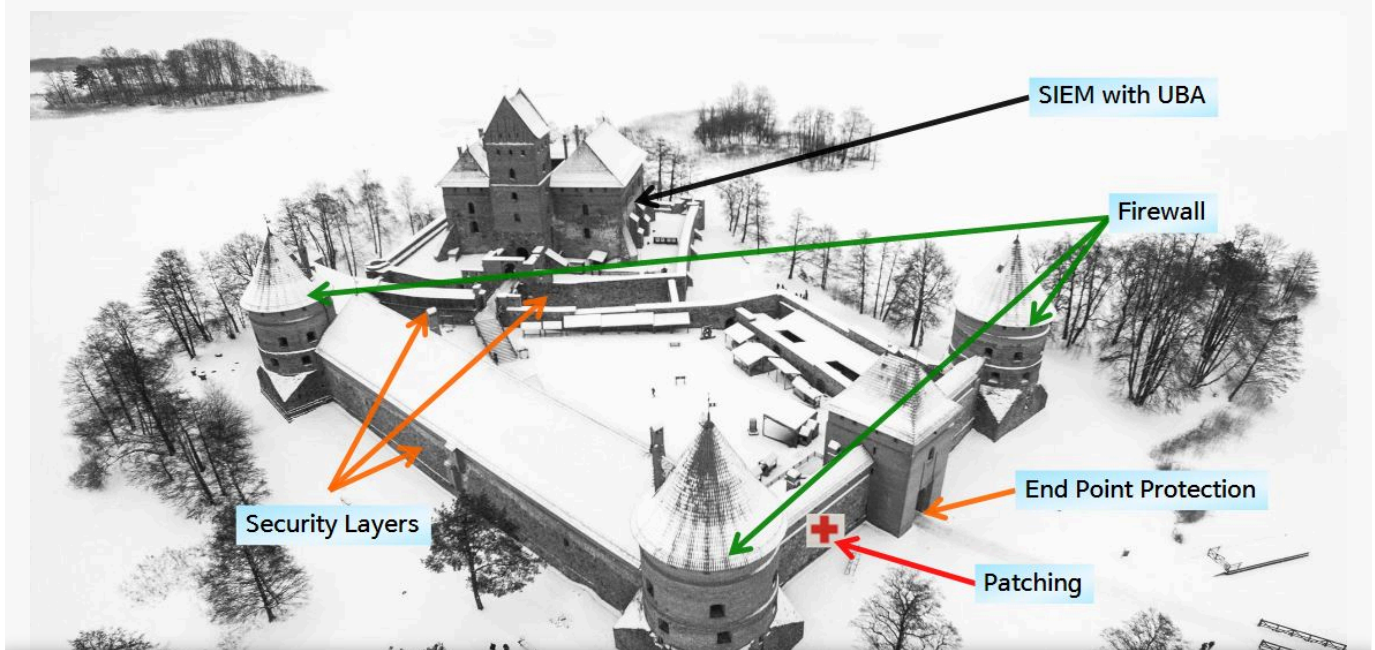
앞서 언급한 KAERI와 KAI의 해킹 사건을 좀 더 분석해 보면, 양 기관은 코로나 확산방지를 위해 일부 직원들의 재택근무를 승인했고 이에 따라 직원들이 자가에서 내부 네트워크에 접속할 수 있도록 VPN 서비스를 이용하였다. 북한으로 추정되는 해킹조직은 이 VPN 서비스의 제로데이 취약점을 이용하여 KAERI와 KAI의 내부 네트워크에 접속할 수 있었고 이번 사건에 의해 유출된 자료의 규모와 내용은 명확히 밝혀지지 않은 상태이다. 악의를 가진 이용자가 내부 네트워크에 접근할 수 있게 되었을 때의 피해는 단순한 자료 유출뿐만 아니라 해당 네트워크의 마비 또는 파괴, 심지어 다른 내부 네트워크로의 이동 등의 행위로 이어질 수 있다. 따라서 군사·국가 중요시설 또는 군사·국가적으로 중요한 기업들이 해킹된다면 최악의 경우 그 수준과 범위를 가늠할 수 없는, 국가적인 재난사태에 버금가는 큰 피해가 발생할 수 있다는 점을 우리는 항상 주지해야 할 것이다. 이번 KAERI와 KAI를 대상으로 한 해킹 공격은 동일한 제로데이 취약점을 사용했다는 점에서 앞서 언급한 미국의 솔라윈즈나 MicroSoft사의 Exchange 사태와 같은 공급망 공격으로 분류할 수 있으며 KA

코로나 사태 이후 우리나라뿐만 아니라 전 세계 각국에서도 재택근무가 적극적으로 도입 및 활성화되면서 VPN 서비스의 취약점을 악용한 해킹위협은 지속적으로 증대되고 있다. 이러한 상황에서 세계적인 IT 기업들은 어떻게 대처하고 있을까?

구글은 VPN 서비스를 사용하지 않는다

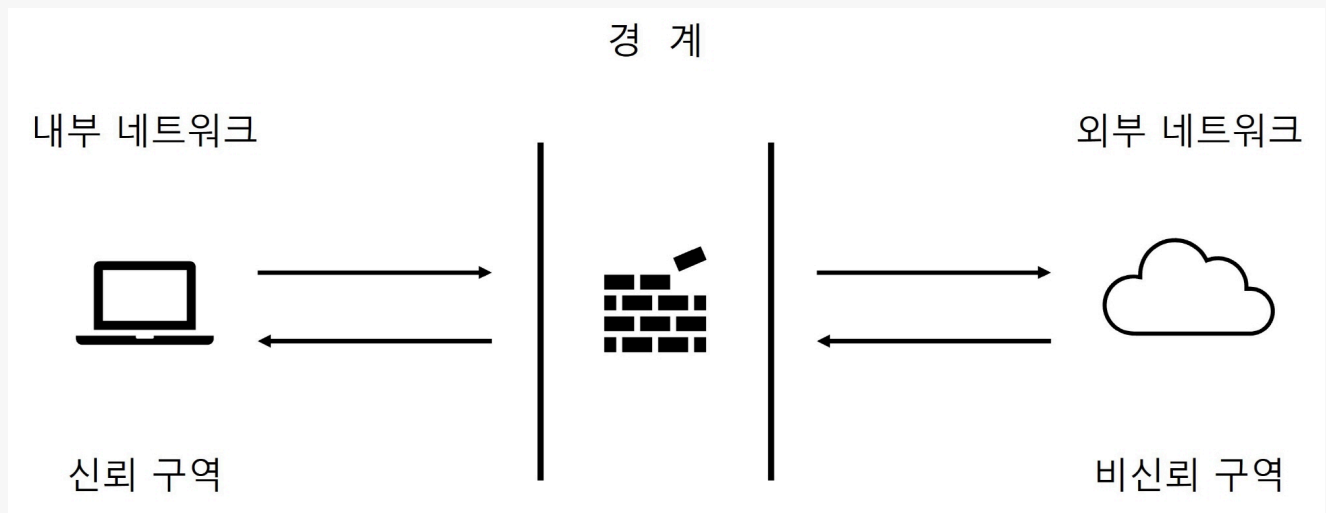
대표적인 글로벌 IT 기업 중 구글의 사례를 살펴보자. 구글은 비교적 최근인 2018년까지도 원격근무를 장려하지 않았던 대표적인 기업이었다. 대신 막대한 자본을 투자하여 기업 활동에 필요한 모든 활동을 회사 내부에서 할 수 있도록 환경을 조성하였고 원격근무는 매우 제한적으로 허용해 왔다. 구글은 직원들이 회사의 기업이념을 잊지 않도록, 그리고 기술 유출 등의 위험을 최소화하기 위해 이처럼 전략적인 접근을 시도했다. 그러나 코로나 사태는 구글까지도 원격근무의 확대 적용을 피할 수 없게 하였고 직원들의 요구와 원격근무의 장점을 확인한 현재의 구글은 코로나 사태가 진정된 이후에도 사무실 구성원의 20%는 원격근무를 허용할 예정이다. 한편, 원격근무를 크게 확대한 구글은 여타 다른 기업들과 다르게 VPN서비스 사용에 따르는 위험을 걱정할 필요가 없었다. 구글은 VPN을 사용하지 않기 때문이다.

구글은 지난 2009년 중국이 미국을 대상으로 감행했던 대규모 사이버 공격 ‘Operation AURORA’의 핵심 표적이 되어 큰 피해를 입은 후 이 사건을 사이버 보안에 대한 개념을 재정립하는 계기로 삼게 된다. 이 때 구글은 전통적인 보안 모델인 경계보안방식을 버리게 된다. 이러한 경계보안방식은 일단 경계 안으로 들어 오기만 하면 대부분의 보안이 무효화된다는 취약점을 내재하고 있다. 구글은 ‘오로라 작전’이라는 해킹 공격으로부터 기존의 경계형 보안으로는 해커들의 공격으로부터 회사를 보호하는데 충분하지 않다는 것을 느끼게 되었고 새로운 개념의 보안모델을 도입하게 된다.



[그림 3] 중세시대 성벽에 비유한 경계형 보안의 예시

구글은 ‘네트워크에 접근하는 것은 어떤 것도 믿을 수 없다’는 원칙을 중심으로 경계형 보안 모델에서 경계가 없는 보안 모델로 전환하게 된다. 이 새로운 보안 모델은 아무도(Zero) 신뢰하지 않는다(Trust)라는 의미로 ‘제로 트러스트’라는 이름을 가지게 되었다. 이 제로 트러스트 모델은 다수의 형태로 구현될 수 있는데 구글이 구현한 모델은 ‘Beyond Corp’로 명명되어 현재는 기업들을 대상으로 한 상용 제품으로써 엔터프라이즈 모델로 판매되고 있다.



[그림 4] 경계형 보안의 개념도

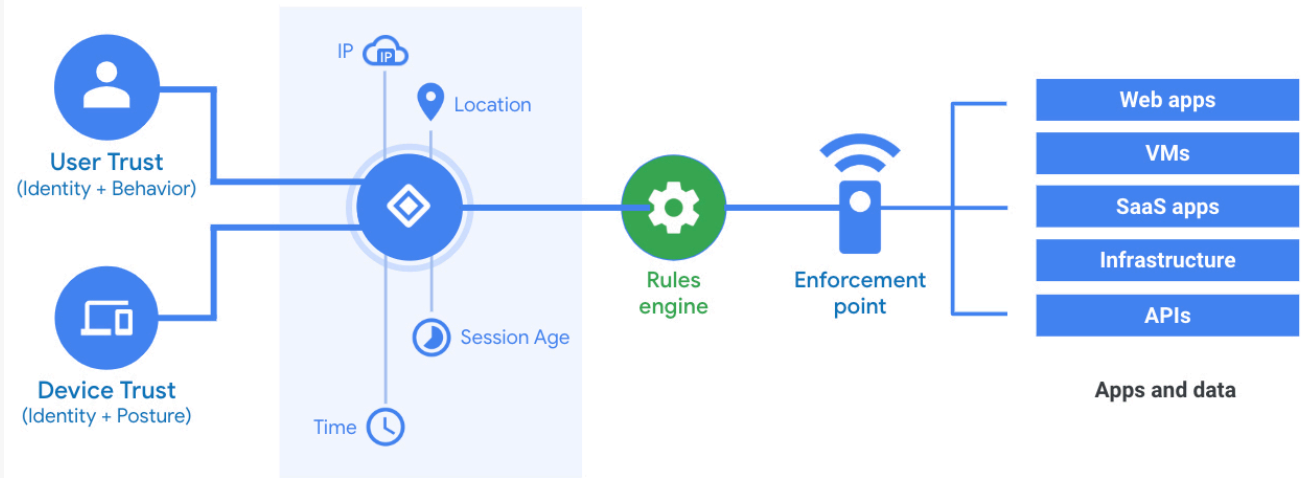
새로운 보안 모델이 필요한 이유

서두에 기술한 바이든 행정부의 행정명령으로 되돌아 가보자. 미국은 왜 제로 트러스트를 도입하려고 할까? 또 이것은 구글의 사이버 보안 모델 전환과 어떤 연관성이 있을까?

기존의 경계형 보안 모델은 내부망 안에서 이뤄지는 통신에 대한 검사능력이 부족했다. 이에 따라 해커가 내부망 침투에 성공하면 내부망 전체가 무방비하게 노출되는 문제가 발생한다. 또한 경계형 보안 모델은 망에 접속하는 사용자의 위치가 한정되어 있어서 장거리 출장이나 기타 사유로 인해서 내부망 외부에서 접속하게 되는 경우 VPN과 같은 다른 접속 수단을 강구해야만 하는 한계점을 가지고 있다. 이외에도 경계형 보안 모델은 그 특성상 여러 제한사항을 가진다.

이에 반해, 제로 트러스트 모델은 경계형 보안 모델에 내재된 한계점들을 극복할 수 있는 모델로서의 가치가 있다.

구글은 전통적인 경계형 보안 모델의 한계를 조기에 인식하고 한발 앞서 제로 트러스트 모델로 전환하였고,



[그림 5] 구글의 Beyond Trust에 대한 개략적인 구조도

구글을 비롯한 세계적인 IT 기업들은 2010년 전후부터 최근에 이르기까지 제로 트러스트의 개념을 세부적으로 정립하고 실제 운용 가능한 수준을 달성하기 위해 분주히 노력하고 있다. 실제로 구글은 제로 트러스트 모델을 도입한 후 정상 운용하는 데까지 무려 6년이라는 시간이 걸렸다.

우리나라 또한 민간기업뿐만 아니라 정부와 군 모두 사이버 공격으로부터 안전할 수 없다. 우리보다 앞서 새로운 보안 모델로의 전환을 추구한 글로벌 기업들의 사례를 참고해 보면, 아직 제로 트러스트의 개념조차 생소한 우리나라에서 이 보안 모델을 도입하여 안정적으로 운용하기 위해서는 10년 이상의 긴 시간이 필요할 지도 모른다. 하루라도 빨리 제로 트러스트 모델을 도입할 수 있도록 모두가 지혜를 모아 서둘러야 할 시점이다.

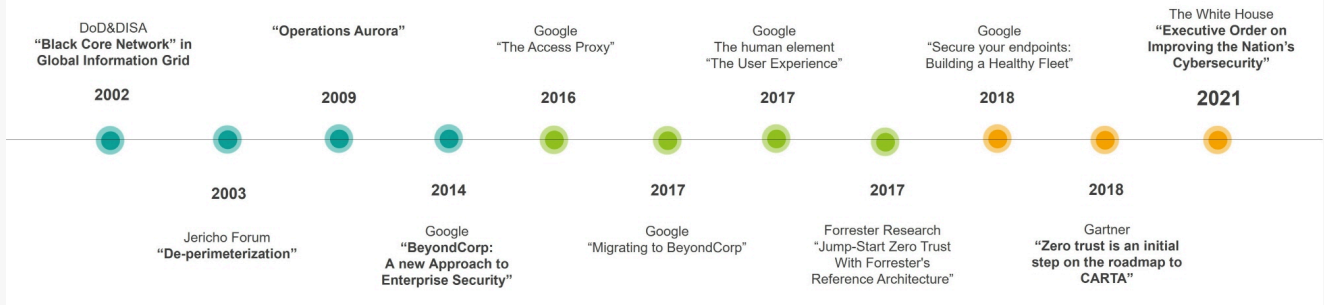
이어지는 글에서는 제로 트러스트의 개념을 알기 쉽게 설명하고 현재 우리 군에서 운용하고 있는 국방망을 대상으로 제로 트러스트 모델을 적용했을 때의 이점을 제시하고자 한다.

제로 트러스트 모델이란?

경계 없는 보안을 의미하는 제로 트러스트 모델은 외부 네트워크만이 아닌 확인된 내부 네트워크에도 공격자가 있다고 가정하여 모든 상황에서 정보보안의 목표를 달성하고자 하는 모델이다.

기존의 경계를 기반으로 하는 보안 모델은 강력한 방화벽 및 게이트웨이 탐지를 구현하기 때문에 내부 네트워크에 대한 외부의 공격자를 효과적으로 차단할 수 있지만, 재택근무자와 같은 외부의 원격작업자, 클라우드 기반 서비스 등은 상대적으로 위협에 노출되어 있기에 안전하지 못하다.

History of Zero Trust Architecture



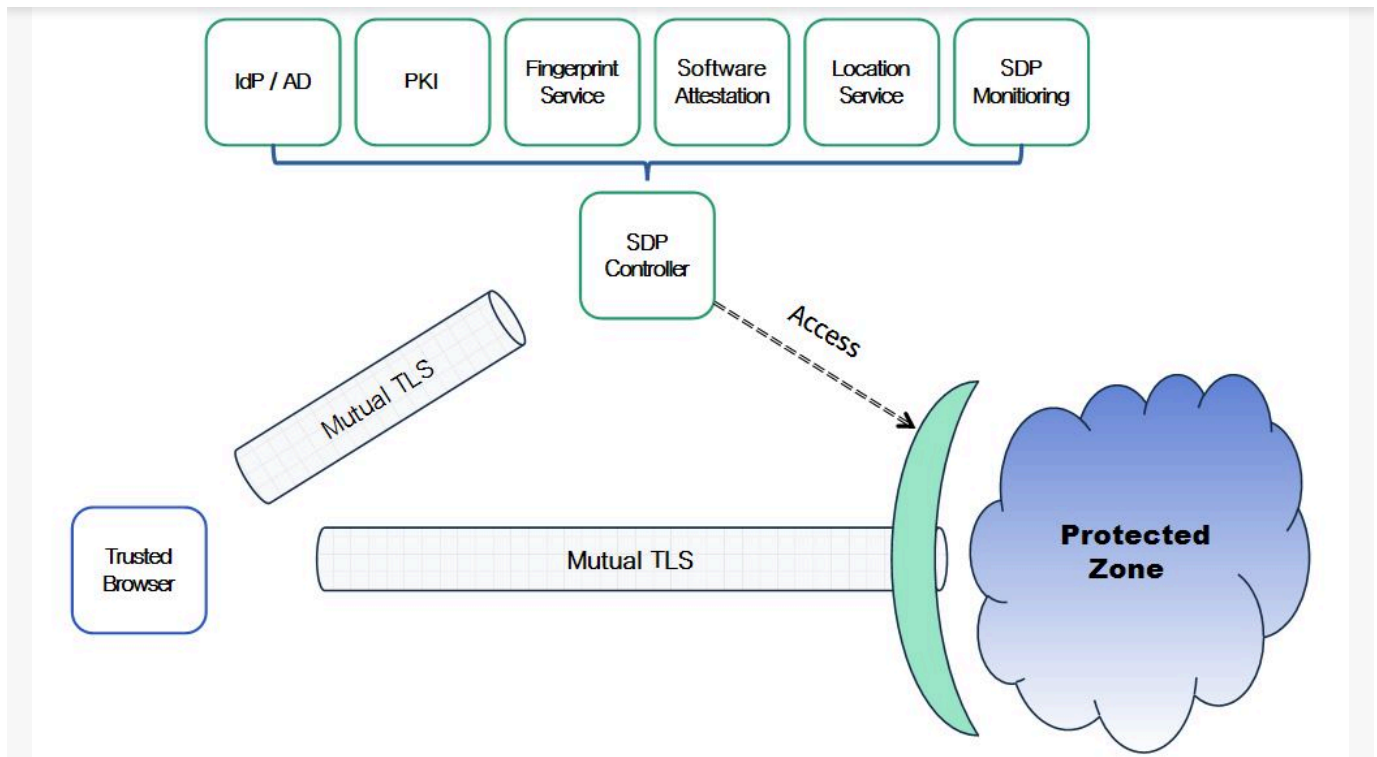
[그림 6] 제로 트러스트 아키텍처 타임라인

제로 트러스트 모델은 그 무엇도 신뢰하지 않으며, 내부 네트워크에 위치한 사용자도 침입자가 될 수 있다고 여긴다. 경계를 지키는 것이 아닌, 데이터를 보호하는 것에 초점을 둔 새로운 보안 아키텍처이며, 데이터에 대한 접근이 발생했을 시 어떤 사용자도 절대적으로 신뢰하지 않고, 지속적으로 사용자가 누구인지, 어떤 용도로, 어떤 데이터에 접근하는 것인지를 계속 확인하여 사용자에게 꼭 필요한 최소한의 권한만 부여하여 다른 데이터에 대한 불필요한 접근을 제한하는 모델이다.

제로 트러스트 모델의 역사

먼저 제로 트러스트 모델이 어떻게 발전해 왔는지 살펴보자.

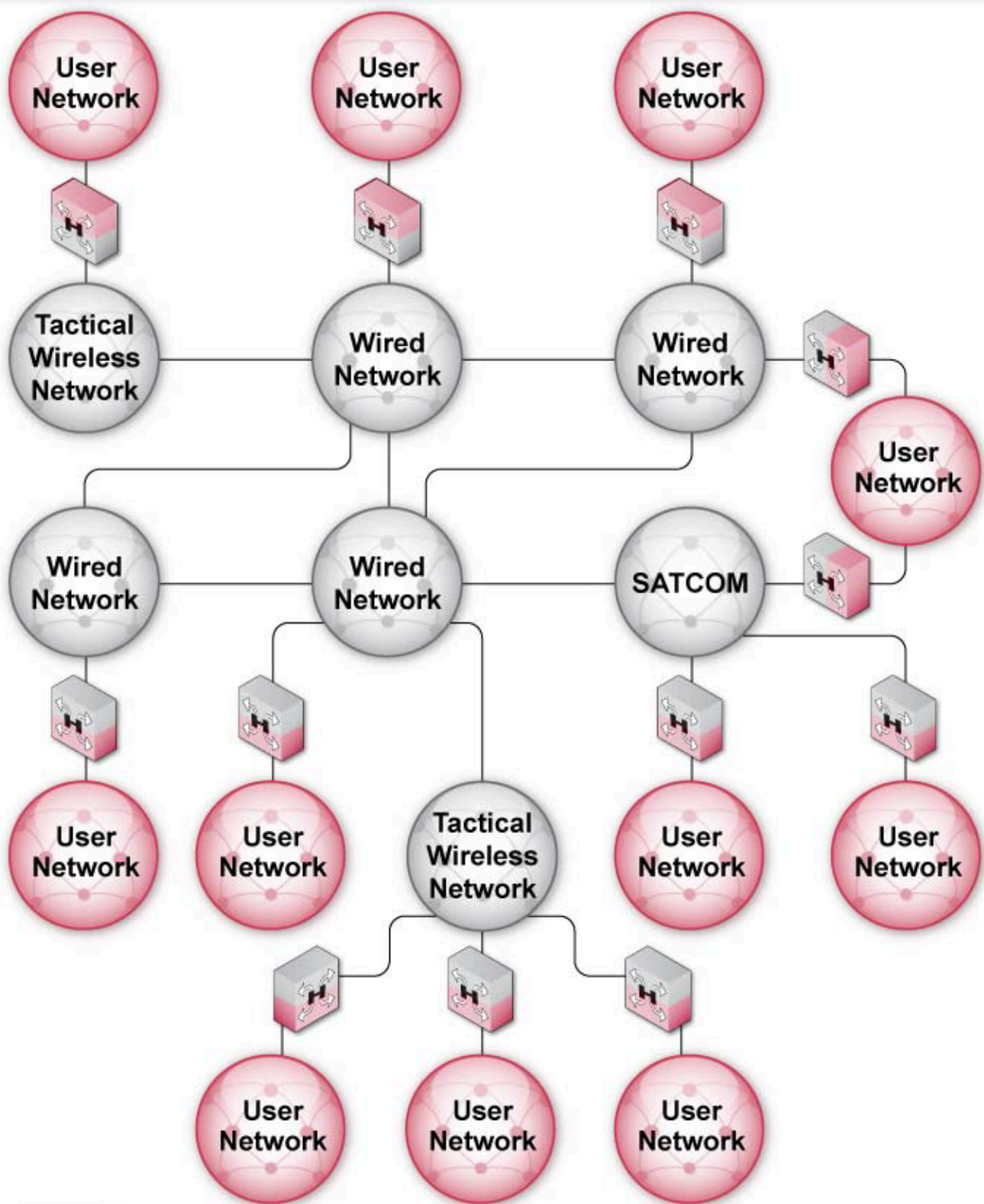
사실 'Zero Trust'의 본질적인 개념은, 용어가 나오기 전에도 이미 사이버 보안 분야에 존재했다. 2002년 미국방부와 국방 정보 체계국(DISA : Defense Information Systems Agency)은 Global Information Grid(GIG)라는 프로젝트를 발표했다. GIG란, 범세계 정보 통신 체계 정도로 설명할 수 있는데 이것은 정보의 수집·처리·저장·배포 및 관리하기 위한 관련 프로세스 및 인력을 통틀어서 이야기하며, 현재는 국방부 정보 네트워크(DoDIN : Department of Defense Information Network)라고 불린다. 이 프로젝트에는 블랙 코어 네트워크(Black Core Network)라는 개념을 포함하고 있는데 이는 경계 기반의 보안 모델보다는 종단간 암호화를 기본으로 하는 네트워크 구조로서 현재 제로 트러스트 모델이나 소프트웨어 정의 경계(SDP: Software Defined Perimeter)의 초기 형태를 가지고 있다.



[그림 7] SDP의 개념도

그 후, 2004년 Jericho Forum에서는 탈경계화(Deperimeterization) 개념을 소개했는데, 네트워크의 위치에 기반한 암묵적인 신뢰와 대규모 네트워크에 대한 경계 기반 보안의 한계를 벗어나기 위한 내용을 담고 있었다. 경계를 지키는 것보다는 데이터를 보호하는 것이 더 중요하다는 개념으로서 세분화 및 단계화된 여러 단계의 보안 레이어를 이용해서 데이터를 보호해야 한다는 내용을 담고 있다.

그 이후 탈경계화의 개념을 Forrester Research의 John Kindervag가 더 큰 개념으로 개선 및 발전시켜 제로 트러스트라는 용어가 탄생하였다. 이 용어가 탄생한 이후에는 기존의 경계기반 보안 모델을 벗어나 네트워크에서 일어나는 각각의 통신에 대한 신뢰도를 평가하는 데 초점을 맞춘 방법들을 설명할 때 제로 트러스트라는 용어가 널리 쓰이게 되었다.



Key:



= Plain Text
User Network



= Black Core
Component Network



= HAIPE or IPsec
Gateway

앞에서 소개한 사례처럼, 세계적으로 많은 기업이 경계형 보안 모델의 한계로 인해 제로 트러스트 모델로의 전환을 시작했다. 다국적 보안 소프트웨어 회사인 Check Point에서 2019년에 실시했던 제로 트러스트 모델 도입 관련 설문을 살펴보면, 52%의 회사는 제로 트러스트를 도입했거나 도입중이고, 18%는 1년 이내에 도입할 계획이었다는 결과를 확인할 수 있다. 설문조사로부터 약 2년이 지났으며 포스트 코로나 시대인 2021년 현재에는 그 비율이 훨씬 더 상승했을 것임은 어렵지 않게 추측할 수 있다.

당신의 조직은 제로 트러스트 모델 도입의 어떤 단계에 있습니까?

단계 구분	비율 (%)
제로 트러스트에 친숙하지 않음	12
1년 이내에 도입할 계획 없음	18
1년 이내에 도입 추진 예정	18
현재 도입중	40
완전히 도입하여 운용중	12

[표 1] Check Point의 제로 트러스트 모델 도입에 대한 기업 대상 설문조사 결과

제로 트러스트 모델이 대세가 되어감에 따라서 미국의 국립 표준기술연구소(NIST : National Institute of Standards and Technology)에서는 제로 트러스트 모델의 표준을 작성하게 된다. 이를 위해서 NIST의 산하기관인 국립 사이버 보안 센터(NCCoE : National Cybersecurity Center of Excellence)에서 미국의 여러 보안 관련 기업 및 기관과 협업하여 제로 트러스트 모델의 표준을 정립하게 된다. 이 프로젝트는 아직 진행형으로, 현재 발표된 표준안은 추가로 수정될 수 있다. 제로 트러스트 모델의 표준안은 NIST.SP.800-207, Zero Trust Architecture이며 이 글도 이 표준안을 기준으로 하여 작성되었다.

제로 트러스트 아키텍처(Zero Trust Architecture) 정의

NIST에서는 제로 트러스트를 “Never Trust, Always Verify”라는 문구로 소개한다. 이를 해석해 보면 “그



[그림 9] Microsoft사의 제로 트러스트 아키텍처 개념도

제로 트러스트는 전통적인 보안 모델인 네트워크 경계를 중점적으로 감시하는 개념에서 탈피해서 서비스를 이용하려는 사용자가 누구인지, 액세스 되는 데이터가 무엇인지와 같은 개체(사용자, 데이터, 전산장비 등) 사이의 개별적 상호 작용에 초점을 둔다. 따라서 제로 트러스트 모델의 보호 대상에는 조직의 네트워크 경계의 밖에 있는 원격 사용자와 네트워크 접속에 사용하는 조직의 소유가 아닌 개인소유의 PC와 모바일 기기까지 포함한다.

제로 트러스트 모델은 어떤 사용자도 절대적으로 신뢰하지 않는다. 각 사용자는 작업에 필요한 최소한의 권한만을 부여받게 되고, 그 부여받은 권한도 지속적으로 검사하여 권한 밖의 데이터는 접근을 제한한다. 사용자가 데이터에 접근하려고 하면, 사용자가 누구인지 신원을 확인하고, 작업에 필요한 최소한의 권한을 부여하며, 주기적으로 접근 권한에 대해 검사를 수행한다.

제로 트러스트 모델을 구현하기 위해서는 건물을 짓는 것처럼 그 구조를 설계해야 한다. 정보보호 장비의 위치, 서버들의 위치와 같은 네트워크 구조로부터, 장비와 사용자에 대한 인증 방법과 절차, 접근제어 방법과 같은 구체적인 보안 정책까지 전체 조직 네트워크의 세부적인 구성과 보안 관련 요소의 동작 및 상호작용을 모두 설계해야 한다. 이러한 보안 구조 설계를 보안 아키텍처라고 한다.

제로 트러스트 아키텍처는 제로 트러스트 모델 구현을 위한 7가지 원칙을 정의했다. 제로 트러스트 모델은 이 7가지 원칙에 따라서 조직의 인프라와 비즈니스 프로세스를 설계 및 구현되어야 한다. ZTA의 7가지 원칙은 다음과 같다.

(1) 모든 데이터 자원 및 컴퓨팅 서비스를 지켜야 할 자산으로 간주한다.

이 원칙은 조직의 네트워크에 존재하는 모든 요소를 자산으로 간주한다는 의미이다. 조직의 네트워크는 다양한 종류의 장비들로 구성되어 있다. 데이터, 서비스, 데이터 수집·저장 장치, SaaS들은 모두 보호해야 할

이 원칙은 네트워크에 접속하는 위치로 자산에 대한 신뢰도를 평가하지 않겠다는 것이다. 네트워크 내부에서 접근할 때와 외부에서 접근할 때 모두 동일한 절차에 따라서 보안 요구사항을 만족해야 한다. 모든 통신은 가장 안전한 방식으로 이루어져야 하며, 기밀성과 무결성을 만족해야 하고, 장비나 사용자와 같은 접속 출처를 인증해야 한다.

(3) 조직의 자산에 대한 접근 권한은 각각의 세션단위로 부여한다.

사용자가 자산에 접근할 때, 어떤 작업에 어떤 권한이 필요한지 미리 파악하여 요청된 작업에 필요한 최소의 권한만을 해당 세션에 부여한다. 세션이 만료되거나 다른 작업을 요청하면 항상 인증절차 등을 다시 거쳐 그에 해당하는 최소한의 권한을 부여해야 한다. 이 원칙을 구현하기 위해서는 초기 설계단계에서 존재하는 작업의 분류와 필요한 권한을 세밀하게 정의해야 한다.

(4) 자산에 대한 접근은 사용자 신원정보, 애플리케이션, 서비스 및 요청 자산의 상태 등 다양한 정보를 고려하여 판단하는 동적 정책에 의해 결정되어야 하며, 다른 동작이나 환경적인 요건도 고려해야 한다.

제로 트러스트 구현을 위해서는 조직이 보유한 자산, 조직의 구성원, 각 구성원에게 필요한 자산의 접근 권한 등이 정의되어 있어야 하며, 다양한 정보들을 취합하고 고려하여 필요한 권한을 부여하는 동적 정책을 적용해야 한다.

이때 수집할 수 있는 정보에는 사용자 신원정보, 자산 정보, 동작 정보, 환경 정보 등이 있다.

- ① 사용자 신원정보에는 계정과 관련된 특성정보, MAC이나 IP 주소, 지문이나 OTP 등의 인증 요소들이 포함될 수 있다.
- ② 자산 정보에는 모든 자산에 설치된 소프트웨어 및 버전 정보, 네트워크 위치, 요청받은 시간 정보, 이전의 동작 정보, 설치된 인증정보(인증서 혹은 세션 정보) 등의 특성이 포함될 수 있다.
- ③ 동작 정보는 자동화된 사용자 및 장비분석과 사용된 패턴들에 대한 측정 정보가 포함될 수 있다.
- ④ 환경 정보는 요청자의 네트워크 위치, 접속 및 작업 요청시간, 탐지된 공격 등의 정보를 포함한다.
- ⑤ 정책은 사용자, 자산, 프로그램 등에 포함된 정보를 기반으로 만들어진 접근 규칙들의 집합을 말하는데, 이는 조직의 비즈니스 프로세스의 요구사항과 조직에서 허용하는 위험 수준을 만족할 수 있도록 개발되어야 한다. 항상 필요한 최소한의 권한만 부여하는 최소 권한의 원칙은 접근 및 확인 권한을 적절히 제한하기 위해 적용된다.

(5) 조직은 어떤 자산도 신뢰하지 않고, 자산의 무결성 및 보안상태를 모니터링하고 측정해야 한다.

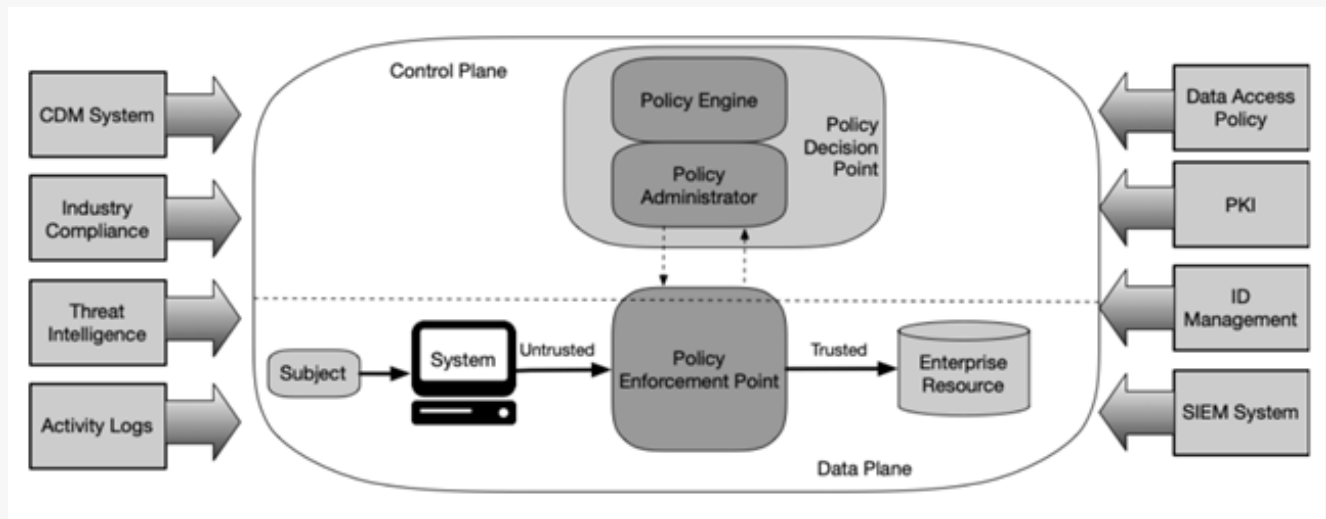
조직은 자산에 대한 요청을 평가할 때 자산에 대한 보안상태도 평가해야 한다. 지속적으로 자산의 상태를 진단하고 위험을 완화하는 시스템(CDM : Continuous Diagnostics and Mitigation)을 수립해야 한다. 만약, 일부 자산이 이미 공격을 받았거나 알려진 취약점을 가지고 있다면 다른 안전한 자산들과는 다른 권한을 받을 수 있다. 예를 들면, 악성코드가 설치된 것으로 평가된 개인 디바이스는 네트워크에 접근하는 것을 거부당할 수 있다.

(6) 자산에 대한 접근을 허용하기 전에, 사용자 및 장비의 인증 및 접근 권한 소지 여부를 동적으로 엄격하게 확인해야 한다.

(7) 조직은 자산의 보안상태, 네트워크 트래픽 및 액세스 요청 정보, 통신상태 등의 최대한 많은 정보를 수집하여 보안 개선에 사용해야 한다.

제로 트러스트 아키텍처에서는 이 원칙들을 각각 특정 기술에 한정하지 않는다. 조직의 상황에 따라 다양한

ZTA 논리적 핵심 구성요소



[그림 10] 제로 트러스트의 논리적 핵심 구성요소

[그림 10]은 제로 트러스트 모델의 대표적인 모델 중 하나이다. 이 모델은, 제로 트러스트의 구성요소와 그 구성요소들의 상호작용 관계를 보여준다. 가운데 제어부를 보게 되면 정책 결정 지점(PDP : Policy Decision Point)과 정책 실행 지점(PEP : Policy Enforcement Point)에서 정책을 결정 및 적용하는 모습을 볼 수 있다. 여기서 정책 결정지점(PDP)은 정책 엔진(PE : Policy Engine)과 정책 관리부(PA : Policy Administrator)로 다시 나누어지는데, 정책 엔진은 자산에 대한 접근요청에 관해 결정을 내린다. 또한 조직의 정책들과 수집한 정보를 이용하여 동적으로 받은 요청에 대해 승인 또는 거부 결정을 내린다. PA는 PE의 결정을 이 행한다. PE가 승인 결정을 내리면 요청자와 자산 사이에 세션을 열어 통신을 연결해 주고, 거부 결정을 내리면 세션을 닫아서 통신을 차단하여 사용자들의 세션과 인증 여부 등 부여된 권한과 같은 정책의 적용을 관리한다. 즉, PDP는 정책을 결정하고 그 정책의 적용을 관리하는 부분이다. PEP는 정책을 관리하는 PA로부터 지침을 받아 통신을 열고 닫는 역할을 하는 문지기이자, 출입을 기록하는 기록자(Logger)로 볼 수 있다. 이 예시모델에서 구현된 ZTA는 이 3가지 구성요소를 이용해 인증, 권한관리, 기록을 가능하게 한다.

조직이 조직의 워크플로우에 대해서 ZTA를 구현하는 방법에는 여러 가지가 있는데, 기본적으로 ZTA의 7가지 원칙을 충족하도록 구현되지만 각 조직의 특성에 따라 ZTA를 다양한 방법으로 다르게 구현할 수 있다. 예를 들어,

- 행위자의 ID를 정책 생성의 핵심 구성요소로 사용할 수도 있으며, 이런 경우에는 ID 및 ID에 부여된 속성에 따라 조직의 데이터에 대한 접근을 감시하여 승인/거부하도록 할 수 있다.
- 지능형 스위치/라우터, 차세대 방화벽, 특수목적 게이트웨이 장치와 같은 특별한 네트워크 장치에 개인데이터를 배치하여 이들을 논리, 물리적으로 분리하여 각 개인데이터를 보호하도록 할 수도 있다.

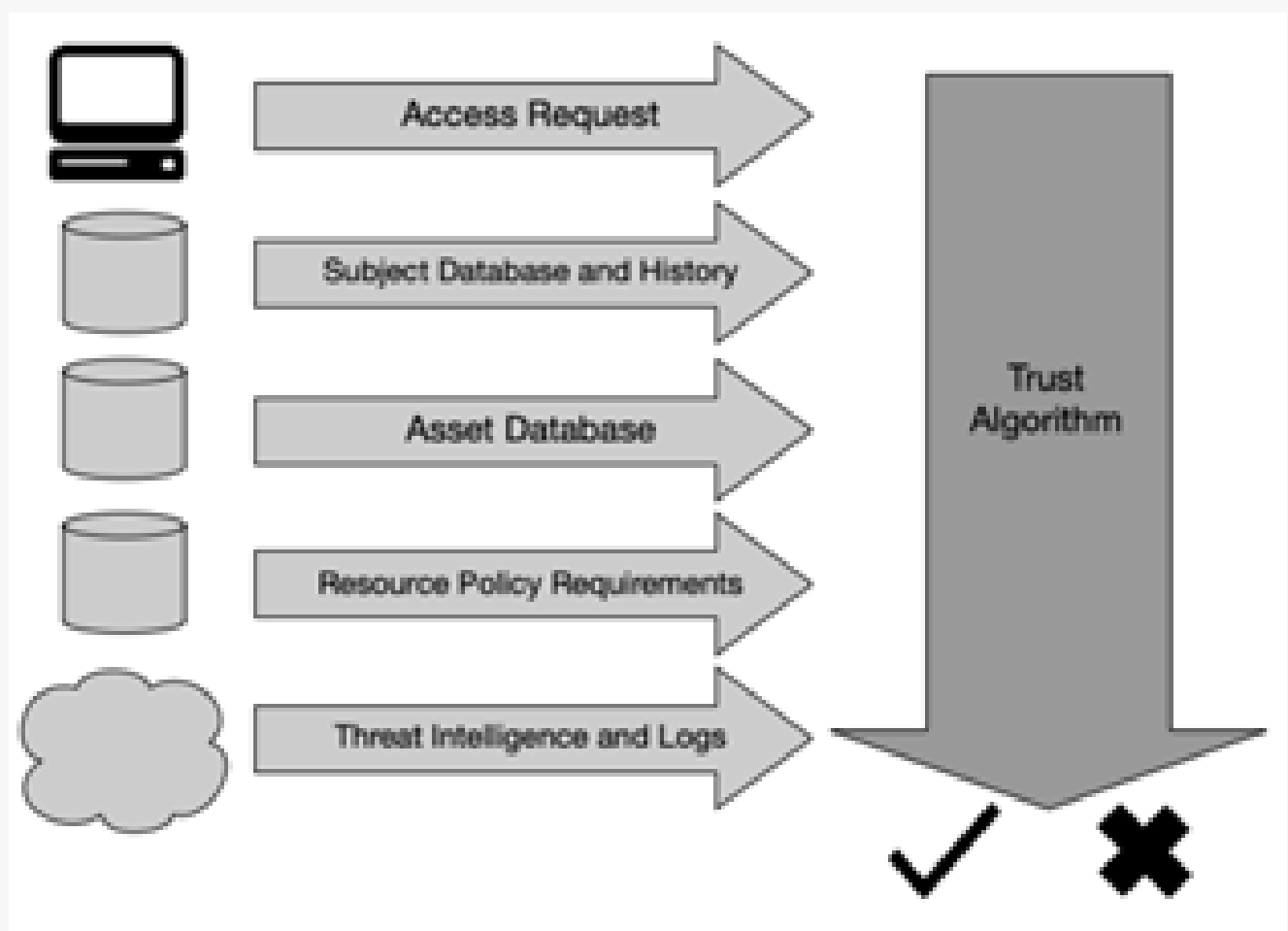
CDP 방식은 사용하여 PE가 어떻게 네트워크를 구성한지를 결정하며 PA가 이를 재구성하고 클라이언트

결론적으로, 어떠한 한정적인 방법에만 얽매일 필요 없이 특성에 따라 각 조직에 적합하도록 7가지 원칙을 충족하게 구현하면 되는 것이다.

신뢰도 알고리즘

ZTA에서 정책 엔진(PE)에 대해 좀 더 자세히 알아보자. 정책 엔진은 정책의 적용 여부를 결정하는 역할을 한다.

PE가 결정할 때는 자산에 접근하는 사용자 혹은 자산의 신뢰도를 평가해야 한다. 그리고 평가한 신뢰도에 따라서 PE가 적용하는 정책이 달라진다. 신뢰도 평가 알고리즘은 다음의 요소들을 평가한다.



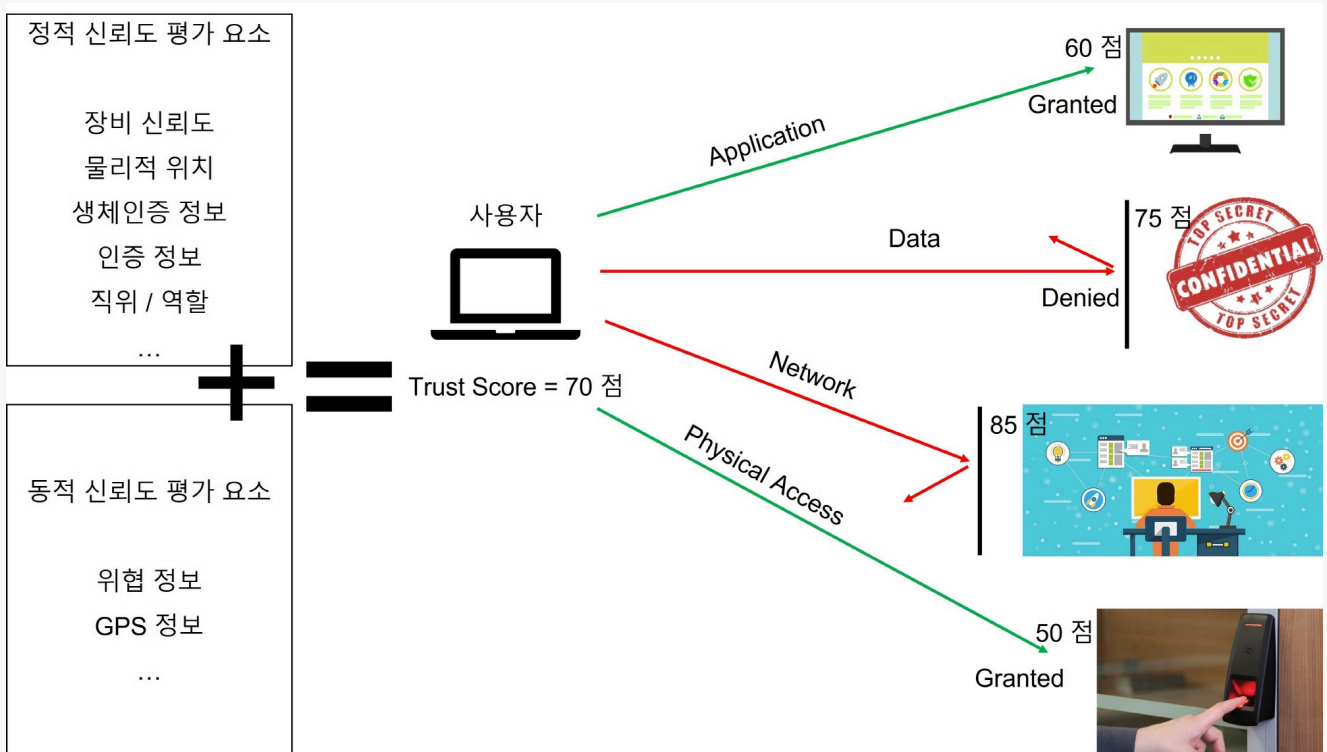
[그림 11] 제로 트러스트의 신뢰도 알고리즘

- 접근요청 : 접근요청 그 자체에 대해 주요 정보를 평가하여 신뢰도에 반영한다. OS 정보, 접근을 요청한 S

신뢰도를 평가한다.

- 자산 데이터베이스 : 조직 소유 혹은 개인소유 장비들의 OS 정보, 설치된 SW 정보, 보안 패치 수준, 무결성, 네트워크상의 위치, 지정학적 위치 등의 정보를 자산에 대한 정보를 유지하고 있는 데이터베이스와 대조하여 신뢰도를 평가한다.
- 자산 요구사항 : 자산이 가지고 있는 데이터와 자산이 조직 업무 프로세스에서 가지고 있는 역할에 따라 해당 자산에 접근하는데 필요한 요구사항이 결정된다. 이 요구사항은 신뢰도에 따라 해당 자산에 접근할 수 있는지 없는지를 결정짓는 요소가 된다.
- 위협정보 : 일반적인 위협과 활성화된 악성코드 위협에 대한 정보를 이용해서 현재 접근요청 주체의 통신 기록이나 행동에서 그리고 자산에 저장된 특정 파일로부터 위협정보를 수집하고 그 위협 수준을 평가하여 신뢰도에 반영한다.

PE는 위 5가지 요소를 고려하여 신뢰도를 평가하고 접근 주체가 자산에 접근할 수 있는지를 결정하게 된다.



[그림 12] 신뢰도 점수방식 알고리즘 적용 예시

이 신뢰도 알고리즘 또한 다양한 방식으로 구현할 수 있다. 대표적으로 기준 중심 방식 또는 점수 중심 방식 그리고 단일 신뢰도 알고리즘 방식 또는 다원 신뢰도 알고리즘 방식이 있다. 기준 중심 방식은 접근 주체가 특정 기준을 넘는지 아닌지를 기준으로 신뢰도를 평가하고, 점수 중심 방식은 접근 주체의 신뢰도를 점수방식으로 산정하여 신뢰도를 평가한다. 단일 신뢰도 알고리즘 방식은 각 요청의 신뢰도를 개별적으로 평가하

신뢰도 알고리즘을 결정하는데 정답은 없다. 모든 조직이 갖추고 있는 환경이 모두 다르므로 ZTA의 논리적 핵심 구성요소를 설계하는 것처럼 해당 환경에서 가장 알맞은 방식을 선택하여 구현하면 된다.

지금까지 제로 트러스트 아키텍처의 특징 및 원칙에 대해서 알아보았다. 요약해 보자면, 제로 트러스트는 네트워크에 존재하는 모든 구성요소를 신뢰하지 않음으로써 조직의 모든 데이터 자원 및 컴퓨터 서비스를 보호한다. 여기서 구성요소란 네트워크에 접속하는 사용자와 장비, 내부 네트워크에 위치해 있는 서버, 네트워크 장비, 정보보호 장비, 각 장비에서 실행되고 있는 프로그램 등 네트워크에 존재하는 모든 요소를 의미한다. 즉, 네트워크 내부의 구성 요소들도 신뢰하지 않는 것이다.

제로 트러스트 아키텍처는 이렇게 네트워크접속 위치로 신뢰도를 판단하지 않으며, 각 데이터 및 자산에 대한 접근이 발생했을 때 접근자의 신원과 권한을 확인하고, 요청 받은 작업에 필요한 최소한의 권한만 부여하여 작업마다 각각의 세션 단위로 접근을 관리한다. 그 후 작업이 종료 됐을 때에는 해당하는 세션을 종료시키고, 다른 작업이 필요하다면 다시 인증을 받아야만 권한을 부여한다.

제로 트러스트의 이러한 개념을 구현하기 위해서는 모든 자산에 대하여 무결성 검사, 감염 여부 등의 상태를 주기적으로 모니터링·측정해야 하며, 사용자 신원, 서비스 요청정보, 자산상태 등 다양한 정보와 네트워크 트래픽 및 통신상태 등의 최대한 많은 정보를 수집하여 보안 개선에 사용하도록 해야 한다.

국방망에 ZTA 적용시 얻는 개선점

제로 트러스트 아키텍처를 국방망에 적용했을 때 얻을 수 있는 개선점에는 무엇이 있을까? 이 글에서 제로 트러스트 아키텍처 도입을 통해 개선하고자 하는 점은 크게 두 가지다.

(1) 사용자별로 접근할 수 있는 서비스가 구분되어 있지 않다.

현재의 국방망은 대부분의 기존 폐쇄형 조직들에서 쓰는 방법인 경계형 기반의 보안 모델을 사용하고 있으며, 물리적인 망 분리에 의존하는 편이다. 현재의 국방망은 폐쇄형으로 분리되어 있으나 내부 네트워크에서 사용자별로 접근할 수 있는 서비스가 세분화 되어 있지 않다. 이 말은 ‘구역’의 개념이 희미하다는 것이다. ‘구역’의 개념이 무엇인지 예를 들면, 한국 대학교의 학생이며 학과는 컴퓨터공학과에 재학중인 A라는 학생이 있으며, 한국 대학교는 외부에서 접근할 수 없는 학교 내부의 네트워크를 구성하고 있다고 하자. 학생 A가 학교 네트워크를 통해 얻고 싶은 정보는 모든 학생이 봐야 하는 학사일정 같은 공통 정보와, 컴퓨터공학과 학생들에게 필요한 학과의 정보가 될 것이다. 그러나 구역의 개념이 존재하지 않는다면, A는 내부 네트워크에 접속하여 컴퓨터공학과 외에 기계공학과, 경영학과, 물리학과와 같은 다른 전공 학생들에게 필요한 정보까지 접근하여 내용을 확인할 수 있을 것이다. 즉, 컴퓨터공학과, 기계공학과, 경영학과, 물리학과 등의 홈페이지 서비스가 사용자별로 세분화되어 있지 않다는 의미이다. 국방망 또한 이러한 부분에서 완전히 자유롭지 못하다.

물론 군의 물리적 보안 강도는 상당히 철저하다. 일반적으로 군부대 내에 몰래 들어가 국방망에 연결되어 있는 PC에 접근하는 것은 사실상 불가능하다고 볼 수 있다. 하지만 외부용역업체·유지보수업체와 같이 업무와 관련되어 군부대에 출입하는 경우 국방망에 직접적으로 접근할 수 있게 된다. 이런 경우에 군 내부의 전산장비에 접근할 수 있다면, 국방망에 공개된 많은 일반 정보에 접근할 수 있게 된다. 즉, 권한이 없는 사용

물론 ‘일반적인 사용자’가 볼 수 있는 정보 대부분은 중요도가 낮은 정보이다. 하지만, 중요도가 낮은 정보를 대량으로 수집하고 집성하여 높은 중요도의 정보로 재가공할 수 있다. 이런 정보는 지능형 지속 공격(APT : Advanced Persistent Threat)조직들이 원하는 정보로 재가공하거나 공격에 활용할 수 있는 단서로 사용될 수 있다. 또한 정보보안에 대한 지식이 뛰어나며 악의적인 의도가 있는 해커가 외부용역업체 또는 유지보수 업체 인원으로 위장하여 침투하게 되는 경우 일반적인 사용자에게 공개된 정보뿐만 아니라 비밀 자료나 비공개 자료도 노출되는 문제가 발생한다. 따라서 우리는 물리적 보안방법에만 의존하는 것이 아니라 근본적인 문제들을 해결해야 한다. 과거, 물리적 보안을 맹신하였으나 사람의 실수(Human Error)로 인해 그것이 무력화되어 무방비하게 노출되었던 사건이 있다. 바로 2016년에 일어난 국방망 해킹 사건이다.

이 사건은 북한 해커 그룹이 백신 납품업체를 해킹하고 백신 서버를 이용하여 군 네트워크 경계의 내부로 침투를 하게 된 사건이다. 누군가의 실수로 인해 군에서 인지하지 못하고 있던 인터넷망과 국방망 간의 접점이 존재하여 발생했던 사건인데, 북한 해커들은 이 접점을 통해서 국방망의 폐쇄망이 제공하는 보안방법을 우회하여 침투할 수 있었으며, 결과적으로 다수의 자료가 유출되었다.

이 사례에서 볼 수 있는 것처럼 기술적인 취약점 혹은 사람에 의한 오류로 인해 외부에서 내부망으로 접근할 수 있는 접점이 발생할 수 있다. 다만, 이런 경우에 외부망의 사용자가 내부망에 접근할 수 있도록 허용하더라도 데이터에 대한 접근을 근본적으로 차단할 수 있는 대책이 있다면 중요한 데이터들은 안전하게 지킬 수 있다.

(2) 각 서비스별로 권한이 세분화 되어 있지 않다.

국방망에서는 특정 데이터가 필요해서 특정 서비스에 접근할 때, 로그인과 같은 인증을 통해 서비스에 접근할 수 있다. 이때, 서비스를 제공하는 서버는 인증 간에 접근을 요청한 사용자에게 부여된 권한을 확인하고, 해당 권한에서 접근할 수 있는 정보만을 확인할 수 있도록 접근을 제어한다.

특정 서비스에서 ‘일반 사용자 권한’을 가진 사용자는 일반 사용자 등급에서 볼 수 있는 데이터에 접근할 수 있고, ‘관리자 권한’을 가지고 있는 사용자는 관리자 등급이 볼 수 있는 데이터에 접근할 수 있다. 권한별로 접근할 수 있는 데이터는 분리되어 있으나 데이터 혹은 그 데이터를 제공 하는 자산별로 권한이 세분화되어 있지는 않은 것이다. 즉, 보안의 핵심이라고 할 수 있는 최소권한의 법칙이 제대로 구현되어 있지 않은 것이다.

데이터별로 접근할 수 있는 권한이 분류되는 것이 아니라 권한에 따라서 접근할 수 있는 데이터가 정해지기 때문에, 침입자가 특정 권한을 갖게 된다면 해당 권한으로 접근할 수 있는 데이터들에 제약 없이 접근할 수 있게 되는 것이다.

이러한 구성 상태에서 침입자가 공격 활동을 통해 조직의 관리자 권한을 얻게 된다면, 침입자는 해당 서비스의 모든 정보를 언제든지 탈취할 수 있다. 따라서 권한 등급을 세분화하여 알맞은 권한을 부여하고, 핵심등급인 관리자 권한의 계정 등은 철저히 보호해야 할 것이다.

국방망에 제로 트러스트 모델을 적용하게 된다면 제로 트러스트 모델 7원칙 중 1, 3, 4, 6번 원칙이 앞에서 설명한 국방망에 개선이 필요한 부분들을 자연스럽게 해결 및 개선할 수 있다. 제로 트러스트 모델은 서비스에 접근할 때마다 해당 사용자가 서비스에 접근할 수 있는 신뢰도를 가졌는지 평가하고 권한을 부여하며, 필요한 수준의 신뢰도가 아닌 경우 추가적인 인증을 하도록 강제한다. 또한 권한별로 접근할 수 있는 데이터가 정해지는 것이 아니라, 데이터별로 접근할 수 있는 권한을 분류하여 데이터에 접근할 때마다 신뢰도를 평가

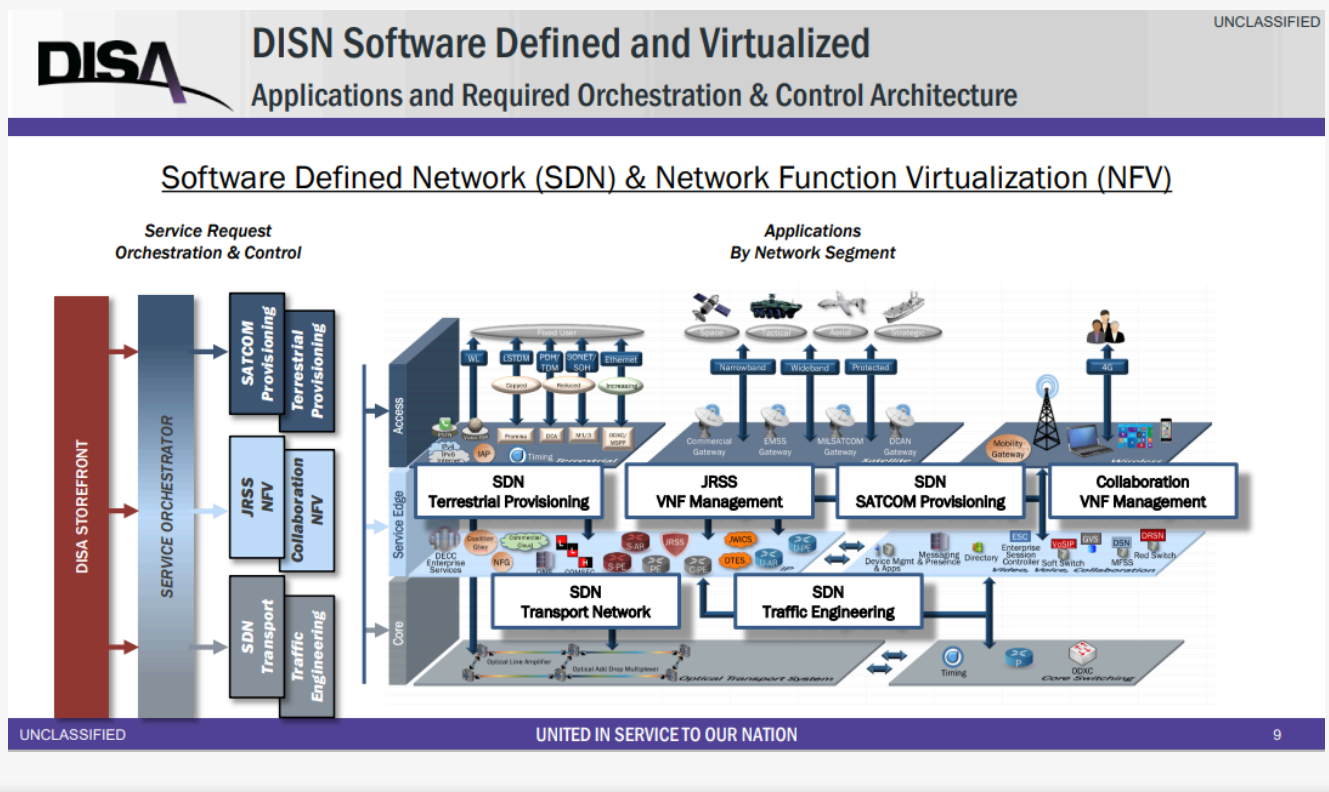
만약, 2016년도 이전에 제로 트러스트 모델이 국방망에 적용되어 있었다면 앞에서 언급했던 국방망 해킹 사건 때 북한 해커가 접근을 통해서 국방망에 들어왔었다더라도 적절한 권한을 얻어내지 못하고 네트워크에서 고립되어 추가적인 침투 및 데이터에 대한 접근이 불가능했을 것이다.

이처럼, 제로 트러스트 모델은 현재 그리고 미래에 일어날 수 있는 보안 사고를 최소화할 수 있는 모델로서 현재 가장 발전된 모습의 보안 모델이다. 우리는 제로 트러스트 모델을 적극적으로 적용하여 우리의 보안을 보다 안전하게 확립해야 한다.

맺는 말

4차 산업혁명 시대에 들어서면서 빅데이터와 AI, 반도체와 전기차, 핵융합과 양자역학, 무선통신과 IoT 등 다양한 분야의 과학기술들이 일반인들에게까지 많은 주목을 받으며 빠르게 발전하고 있다. 민·관·군 모든 영역에 걸친 과학기술의 적용에는 중요한 핵심 요소가 있다. 바로 보안(保安)이다.

세계 최고의 기술력과 최강의 군사력을 보유한 미국에서는 4차 산업혁명 시대를 맞아 사이버 보안에 대한 중요성을 심각하게 인지하고 대비책을 마련했다. 그 결과 비교적 이른 2002년부터 GIG의 Black Core Network의 개념을 제시하고 꾸준히 발전시켜 현재는 경계형 기반에서 탈피한 새로운 아키텍처를 적용 및 운용하고 있다. 나아가 그 상태에 만족하지 않고 [그림 13]처럼 현재까지도 지속해서 네트워크 모델과 보안 모델을 발전시켜 나가고 있다.



이렇듯 보안 문제에 선제적으로 대응해 온 미군과 대조적으로 우리 군은 아직 기존의 보안방식을 벗어나지 못하고 있다. 전통적인 보안 모델에서 현실적으로 대응할 수 있는 최선의 선택을 하고 있음은 틀림없으나 이 제는 과감한 혁신이 필요한 시기가 다가왔다.

대부분 과학기술은 개발 이후 적용되기까지 적용 대상에 맞는 상당한 검증과 설계 기간이 필요하다. 기밀 사 항이 다수인 국가안보를 다루는 군에 새로운 보안 아키텍처를 적용하려면 그 도입 기간은 예상보다 훨씬 길 어질 것이 명백하다.

최근 군에서도 새로운 기술들의 도입과 적용을 통한 발전 방안을 검토하고 있다. 일례로 모바일과 클라우드 서비스의 도입을 위한 정량적 검토가 진행되고 있으며 일부 분야는 이미 도입 추진단계까지 진행된 것으로 알려져 있다.

다만 그 동안 군 내에 편리한 최신 과학기술을 적용하는 데에는 보안 문제에 따르는 애로사항이 다수 있었던 것이 사실이다. 약 10여 년 전 모바일 서비스를 통한 업무와 무선 서비스 도입에 대해 검토단계까지 이르렀 으나 보안 문제를 해결하지 못해 최종적으로 무산되었던 안타까운 사례가 있었다. 2021년 절반이 지난 지금 까지도 군내에서의 무선통신이나 모바일, 클라우드 서비스의 이용은 불가하다.

하지만 우리 군이 제로 트러스트 모델을 도입한다면 앞서 언급한 서비스들을 군 내에서 사용하는 것이 더 이 상 몽상이 아니다. 언제, 어디서, 누가, 왜, 어떤 서비스를, 어떻게 사용하는지에 무관하게 모든 사용자가 동 일한 보안 절차를 통해 서비스를 이용하므로 어떠한 조건에서도 보안 문제를 예방할 수 있기 때문이다. 즉, 최신 과학기술을 이용한 서비스를 새롭게 도입할 때에도 제로 트러스트 모델을 통해 보안 문제를 예방할 수 있다. 따라서 제로 트러스트 모델은 군이 새로운 기술을 도입하거나 신종 사업을 추진할 때 한층 속도를 낼 수 있도록 도와줄 것이다.

군이 4차 산업혁명 시대에 걸맞은 보안성을 갖추기 위해서, 또 견잡을 수 없는 속도로 발전하는 과학기술을 군에 신속하게 도입하여 현대화된 정예강군 육성을 위해서는 한시라도 빨리 제로 트러스트 아키텍처의 개념 을 군에 적용하기 위한 사전준비를 시작해야 한다.

대표 이미지



0.jpg

목록

많이 본 BEMIL 뉴스

1 [2026 국군 무기도감] 업그레이드 참수리 'R' 추가 ... 압도적 화력 ...	6 HD현대중공업, 필리핀 원해경비함 5개월 앞당겨 조기 인도	11 [전장 판도 바꾸는 드론, 마이크로파 한 방에 군집
2 北 24시간 실시간 감시...국산 중고 도 정찰 무인기 'MUAV' 1호기 출고	7 “폴란드형 K2 전차 보러오 세요”...현대로템, 동유... 1 댓글	12 ‘해병의 첫 코뿔소’ 현대. 템, 장애물개척전차 해..
3 해병 최초의 고속전투주정 ‘청새치’ 진수...시속 80... 5 댓글	8 LIG 디앤에이, 유도로켓 ‘비궁’ 美 수출 위한 교두보로 현지법인 설립	13 [BEMIL 현장취재] 현존 고 재래식 디젤 잠수함 '...
4 세계 자주포시장 최강자 K90I 美시장도 공략한... 1 댓글	9 [최신 무기의 세계] 대형 수직이착 륙 전투용 무인기 ‘공중전 게임체...	14 KAI, 한국형전투기(KF-2 장시험 사업 계약 체결

커뮤니티 인기 게시물

1 L3 조기경보기 실물기체(와 유사한) 미 해군 운용 전자전기 NC-37B

2 중국의 정체불명 무장 컨테이너 선박

3 미국 F-47 탑재 후보, 프랫&휘트니 XA103 가변사이클 엔진 공개



4 중국 항모들의 근황

5 2026년 중국 공산당 인민해방군 대만 침공 작전 시나리오 분석

6 북한의 신형 CIWS

7 강건함의 바우소나

8 KF21시제기 가 인도네시아로 보내진다고 합니다.

9 The invasion of Venezuela is imminent

10 [BEMIL 현장취재] K4-II 40mm 고속유탄기관총, 각종 광학장비 등 ADEX 2025 보병 무기체계
모음



BEMIL 뉴스

BEMIL 포커스

커뮤니티

고객센터

[개인정보처리방침](#) | [제휴문의](#) | [이용약관](#) | [회원정보변경](#) | [운영사 소개](#)

Copyright (c) BEMIL 군사세계 All rights reserved.